PORTOFOLIO ARTIFACT

DIGITAL PRODUCT LEGAL & GOVERNANCE ASSESSMENT

ANALISIS HUKUM TERHADAP TINDAK PIDANA *PHISHING* DALAM PENCURIAN DATA PRIBADI NASABAH PERBANKAN DIGITAL DI INDONESIA

Mata kuliah Cybersecurity Law and Policy

Disusun oleh :

Karine Olivia Permana	2024071025
Keren Sandra Sudarta	2024071031

PROGRAM STUDI INFORMATIKA

UNIVERSITAS PEMBANGUNAN JAYA

TANGERANG SELATAN

2026

1. Product & Service Overview

- Nama Produk : Platform Layanan Perbankan Digital (Mobile Banking & Internet Banking).
- Deskripsi Layanan : Aplikasi seluler dan portal web yang menyediakan layanan finansial kepada nasabah, meliputi transfer dana, pembayaran, pembukaan rekening, dan manajemen aset secara online 24/7.
- Deskripsi Kasus & Modus Operandi : Terjadi aksi Phishing berupa pembuatan situs web/iklan tiruan (spoofing) dan penyebaran tautan/file berbahaya yang mengarahkan nasabah untuk memasukkan data sensitif seperti *username*, *password*, nomor kartu kredit/debit, OTP, dan PIN transaksi. Data pribadi yang telah masuk kemudian dimanfaatkan oleh pelaku untuk menguras saldo nasabah.

2. Digital Asset & IP Register

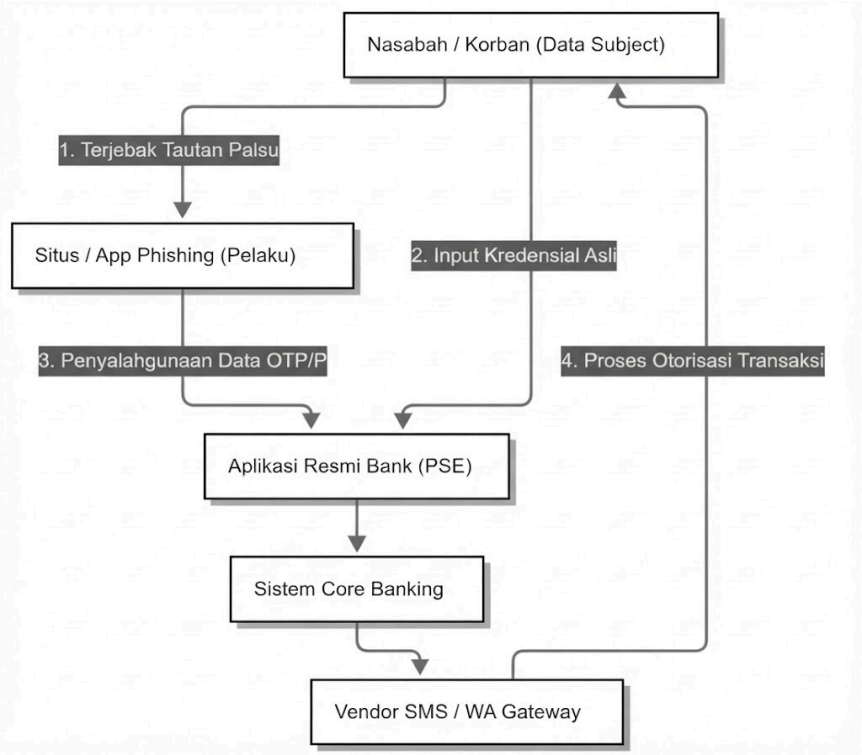
No	Jenis Aset Digital	Deskripsi Aset	Jenis Kekayaan Intelektual (KI)	Status Kepemilikan
1	UI/UX & Tampilan Website	Antarmuka grafis, tata letak, dan skema warna aplikasi *M-Banking*.	*Copyright*	Bank (Internal)
2	Merek & Logo Bank	Identitas visual, nama aplikasi, dan *branding* resmi.	*Trademark*	Bank (Internal)
3	Source Code M-Banking	Kode program frontend, backend, dan API sistem perbankan.	Hak Cipta/Rahasia Dagang	Bank/*Developer*

4	Database Nasabah	Data KTP, Nomor Rekening, Rekam Transaksi, Data Biometrik.	*Rahasia Dagang/Data Terproteksi*	Bank (Pengendali data)
5	Situs/Domain Phishing	Domain tiruan (bank-resmi-login.com) yang digunakan pelaku.	*Domain Name Spoofing*	Ilegal/Pelaku

3. Ownership/Licence/Evidence Map

- Kepemilikan Aset Legal : Bank memegang Bank memegang penuh Hak Cipta atas *source code*, desain UI/UX, serta Merek Terdaftar untuk logo dan nama aplikasi.
- Lisensi & Hak Akses Nasabah: Nasabah diberikan lisensi non-eksklusif (*End User License Agreement / EULA*) untuk mengunduh dan menggunakan aplikasi perbankan digital sesuai syarat dan ketentuan yang berlaku.
- Pemetaan Bukti (Evidence Map) Kasus Phishing:
    - Bukti Digital Utama: *Server log* perbankan, riwayat alamat IP pengakses, riwayat lalu lintas SMS/WhatsApp OTP, bukti tangkapan layar (*screenshot*) situs *phishing*, serta file APK berbahaya.
    - Digital Forensics: Ekstraksi *header* email/pesan, analisis rekayasa balik (*reverse engineering*) file APK, serta pendaftaran IP/domain palsu melalui lookup WHOIS.

4. System & Actor Architecture



Daftar Aktor & Peran:

1. Nasabah (Data Subject): Pemilik data pribadi yang menjadi sasaran rekayasa sosial (*social engineering*).
2. Pelaku Kejahatan (Phisher/Attacker): Pihak ketiga tidak sah yang mereplikasi aset visual bank untuk mencuri kredensial.
3. Bank (Data Controller & Provider): Penyedia layanan digital banking yang mengelola sistem dan memegang tanggung jawab pelindungan data.
4. Vendor Telekomunikasi / SMS-WA Gateway: Pihak ketiga penyedia infrastruktur pengiriman OTP/notifikasi.
5. Pihak Berwajib & BSSN: Lembaga regulasi dan penegak hukum (Polri/Cyber Crime, OJK, BSSN).

5. Applicable Law Map (Regulasi Terkait di Indonesia)

1. UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (UU PDP):
    - *Pasal 65 & 66:* Larangan memperoleh, mengumpulkan, dan menggunakan Data Pribadi secara melawan hukum (Sanksi pidana penjara max 5 tahun dan/atau denda max Rp5 miliar).

    - *Pasal 16 & 46:* Kewajiban Penyelenggara Sistem Elektronik (Bank) untuk menjaga keamanan data pribadi nasabah dan memberitahukan kegagalan pelindungan data (bila terjadi *data breach*).
2. UU No. 1 Tahun 2024 (Perubahan Kedua UU ITE / UU No. 11 Tahun 2008):
    - *Pasal 28 ayat (1) & Pasal 45A:* Penyebaran berita bohong/penipuan yang merugikan konsumen dalam transaksi elektronik.
    - *Pasal 30 & 32:* Akses ilegal (*illegal access*) terhadap komputer/sistem elektronik orang lain dan manipulasi/pencurian data elektronik.
    - *Pasal 35 & 51 ayat (1):* Pembuatan/manipulasi Informasi/Dokumen Elektronik seolah-olah otentik (*spoofing/phishing*).
3. UU No. 28 Tahun 2014 tentang Hak Cipta & UU No. 20 Tahun 2016 tentang Merek:
    - Penggunaan tanpa izin atas logo, merek, dan tampilan UI/UX bank oleh pelaku *phishing* melanggar hak eksklusif kekayaan intelektual bank.
4. Peraturan Otoritas Jasa Keuangan (POJK) No. 11/POJK.03/2022:
    - Tentang Penyelenggaraan Teknologi Informasi oleh Bank Umum (Kewajiban ketahanan siber dan perlindungan nasabah).

6. Vendor / Platform / Data Responsibility

- Tanggung Jawab Bank (Data Controller):
    - Memastikan keberlangsungan enkripsi data (*end-to-end encryption*), otentikasi dua faktor (2FA/Biometrik), dan mitigasi keandalan sistem.
    - Mengedukasi nasabah secara berkala mengenai bahaya *phishing* dan menjaga agar kerahasiaan OTP tidak bocor dari internal bank.
- Tanggung Jawab Vendor Pihak Ketiga (Platform/Gateway):
    - Vendor penyedia infrastruktur cloud dan OTP wajib menjamin ketersediaan jalur komunikasi yang aman serta tidak membocorkan lalu lintas pesan/log transaksi.
- Tanggung Jawab Nasabah (End-User):
    - Menjaga kerahasiaan kredensial pribadi (PIN, Password, OTP) dan tidak membagikannya kepada pihak mana pun sesuai asas kehati-hatian (*duty of care*).

7. Risk & Control Matrix

No	Identifikasi Risiko	Tingkat Risiko	Dampak Hukum & Bisnis	Mitigasi & Kontrol Pengendalian
1	Credential Stuffing / Phishing Page	Tinggi (High)	Kerugian finansial nasabah, gugatan perdata, dan penurunan reputasi bank.	Menerapkan *Multi-Factor Authentication* (MFA) berbasis biometrik/Passkey, serta pemantauan domisili IP berisiko.
2	Malware / APK Phishing	Tinggi (High)	Pengambilalihan kontrol perangkat nasabah dan intersept SMS OTP.	Implementasi *App Sandboxing*, pencegahan eksekusi pada *rooted/jailbroken device*, dan deteksi *Accessibility Service* berlebihan.
3	Pelanggaran Merek & UI Spoofing	Sedang (Medium)	Penyesatan publik dan pelanggaran Hak KI bank.	Melakukan *Takedown Notice* secara responsif terhadap domain/situs web tiruan dan akun media sosial palsu.
4	Sengketa Tanggung Jawab Kerugian	Tinggi (High)	Potensi sanksi administratif OJK/UU PDP jika terbukti ada kelalaian keamanan sistem internal.	Penyelenggaraan audit forensik digital berkala (*Penetration Testing*) dan *Log Auditing* untuk pembuktian di pengadilan.

8. Executive Recommendations

Penguatan Otentikasi & Keamanan Sistem (Technical Action):

- Migrasi dari SMS OTP ke *In-App Token* / Otentikasi Biometrik terenkripsi guna meminimalkan risiko intersept pesan teks.
- Mengimplementasikan fitur *Anti-Phishing Shield* pada aplikasi yang mampu mendeteksi keberadaan aplikasi pihak ketiga berbahaya (seperti APK penyadap) pada perangkat nasabah.

Sistem Takedown Otomatis & Brand Protection (Legal Action):

- Bekerja sama dengan Kementerian Komdigi (Kominfo), BSSN, dan penyedia registri domain untuk membuat mekanisme *fast-track takedown* bagi situs/domain *phishing*.
- Mengajukan laporan pidana secara proaktif berdasarkan Pasal 35 & 51 UU ITE atas tindak manipulasi dokumen elektronik dan pelanggaran merek.

Penyusunan Keijakan Ganti Rugi & Klaim (Governance Action):

- Menyusun SOP investigasi yang transparan berdasarkan analisis log forensik digital untuk menentukan apakah kasus merupakan kelalaian murni nasabah (*social engineering*) atau kelemahan sistem perbankan.

Edukasi & Literasi Digital Nasabah (Operational Action):

- Meningkatkan kampanye literasi digital secara konsisten mengenai kerahasiaan data pribadi sesuai amanat UU PDP.

Daftar Referensi

Otoritas Jasa Keuangan. (2022). *Peraturan Otoritas Jasa Keuangan Nomor 11/POJK.03/2022 tentang Penyelenggaraan Teknologi Informasi oleh Bank Umum*. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 63. https://ojk.go.id/id/regulasi/Pages/Penyelenggaraan-Teknologi-Informasi-Oleh-Bank-Umum.aspx

Republik Indonesia. (2014). *Undang-Undang Nomor 28 Tahun 2014 tentang Hak Cipta*. Lembaran Negara Republik Indonesia Tahun 2014 Nomor 266, Tambahan Lembaran Negara Republik Indonesia Nomor 5599. https://peraturan.bpk.go.id/Details/38690/uu-no-28-tahun-2014

Republik Indonesia. (2016). *Undang-Undang Nomor 20 Tahun 2016 tentang Merek dan Indikasi Geografis*. Lembaran Negara Republik Indonesia Tahun 2016 Nomor 252, Tambahan Lembaran Negara Republik Indonesia Nomor 5953. https://peraturan.bpk.go.id/Details/37595/uu-no-20-tahun-2016

Republik Indonesia. (2019). *Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik*. Lembaran Negara Republik Indonesia Tahun 2019 Nomor 185, Tambahan Lembaran Negara Republik Indonesia Nomor 6400. https://peraturan.bpk.go.id/Details/122030/pp-no-71-tahun-2019

Republik Indonesia. (2022). *Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi*. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 207, Tambahan Lembaran Negara Republik Indonesia Nomor 6835. https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022

Republik Indonesia. (2024). *Undang-Undang Nomor 1 Tahun 2024 tentang Perubahan Kedua atas Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik*. Lembaran Negara Republik Indonesia Tahun 2024 Nomor 10, Tambahan Lembaran Negara Republik Indonesia Nomor 6952. https://peraturan.go.id/id/uu-no-1-tahun-2024